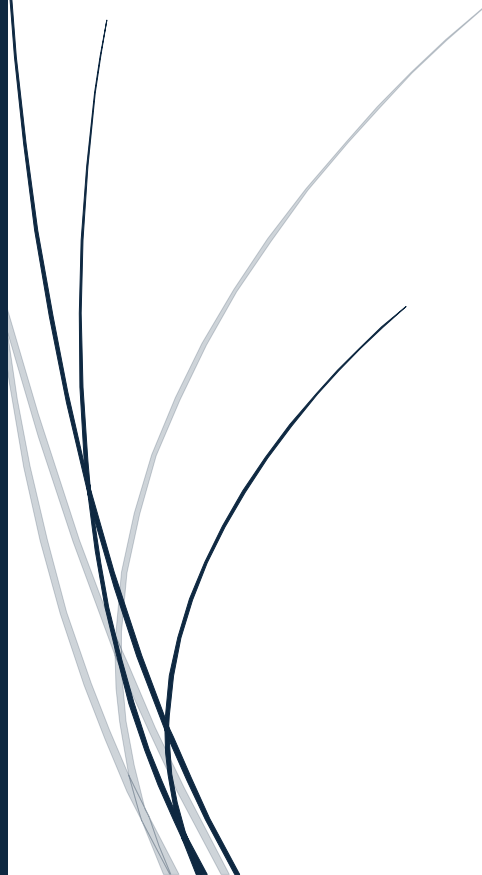


25 de septiembre del 2026

Lab: File path traversal, validation of start of path

CNO IV – Seguridad Informática

Profesor: Servando López Contreras Universidad Politécnica de San Luis Potosí
--



Luis Felipe Jaramillo Barajas
MATRICULA: 183559

Contenido

1. Introducción	2
2. Objetivos	2
Objetivo general	2
Objetivos específicos.....	2
3. Preparación del laboratorio	3
4. Fase 1: Interceptación y confirmación del formato del parámetro	3
5. Fase 2: Confirmación de la validación de prefijo	5
6. Fase 3: Construcción del payload y explotación.....	5
6.1 Explicación del payload	7
6.2 Resolución del laboratorio	7
7. Mitigación recomendada.....	8
8. Conclusiones	8

1. Introducción

A diferencia de los laboratorios anteriores, en este caso la aplicación transmite la ruta completa del archivo a través del parámetro de la petición y valida únicamente que dicha ruta comience con el directorio esperado (por ejemplo, `/var/www/images/`).

Esta validación parcial no impide que, tras el prefijo válido, se incluyan secuencias de retroceso de directorio que reconduzcan la ruta final fuera del directorio permitido, hasta llegar al archivo `/etc/passwd`.

2. Objetivos

Objetivo general

Demostrar la capacidad de evadir una validación de ruta que solo comprueba el prefijo inicial de la cadena, añadiendo secuencias de traversal después de dicho prefijo para acceder a un archivo fuera del directorio permitido.

Objetivos específicos

- Identificar que el parámetro `filename` transmite la ruta completa del archivo, no solo su nombre.
- Comprender la debilidad de una validación que solo verifica el inicio de una ruta.
- Construir un payload que conserve el prefijo válido y añada secuencias de traversal tras él.
- Acceder al contenido del archivo `/etc/passwd`.
- Proponer medidas de mitigación adecuadas.

3. Preparación del laboratorio

La aplicación transmite la ruta completa del archivo mediante un parámetro de petición y valida que dicha ruta comience con la carpeta esperada. El objetivo es recuperar el contenido de `/etc/passwd`.

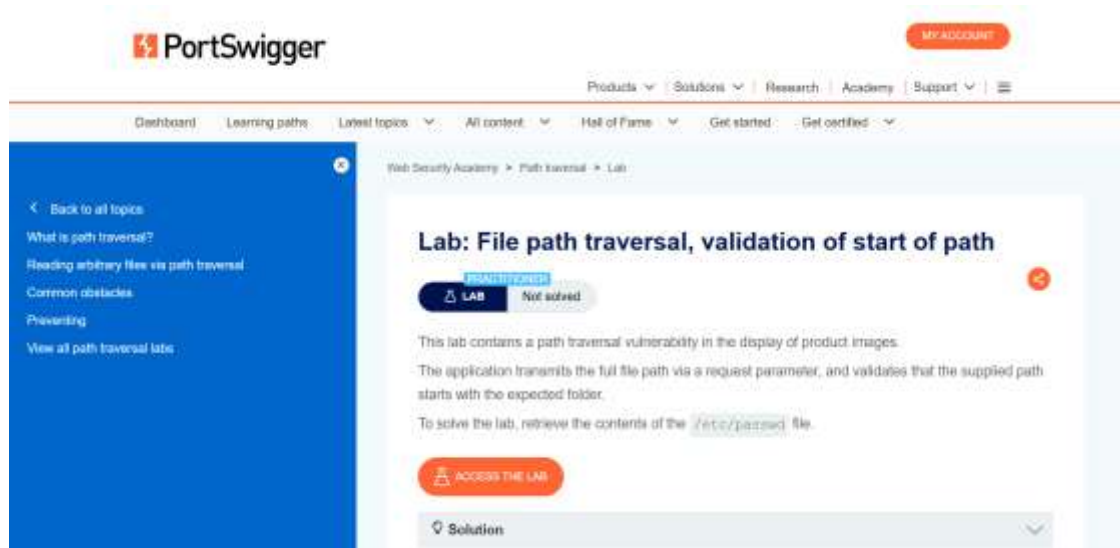


Figura 1. Descripción del laboratorio “Validation of start of path” en PortSwigger Web Security Academy.

Concepto teórico: validación de prefijo (startsWith). Una práctica común, pero insuficiente por sí sola, para restringir el acceso a archivos es comprobar que la ruta proporcionada por el usuario comience con el directorio base permitido, típicamente mediante una función del tipo `path.startsWith(BASE_DIRECTORY)`. El problema es que esta comprobación no analiza el resto de la ruta: si después del prefijo válido se añaden secuencias “`../`”, la ruta seguirá “comenzando” con el directorio esperado, pero al resolverse apuntará a una ubicación completamente distinta, fuera de dicho directorio.

4. Fase 1: Interceptación y confirmación del formato del parámetro

Con el proxy activo, se navegó por el catálogo de “We Like To Shop”. A diferencia de los laboratorios anteriores, en este caso el parámetro `filename` no contenía únicamente un nombre de archivo, sino la ruta absoluta completa del recurso en el servidor.

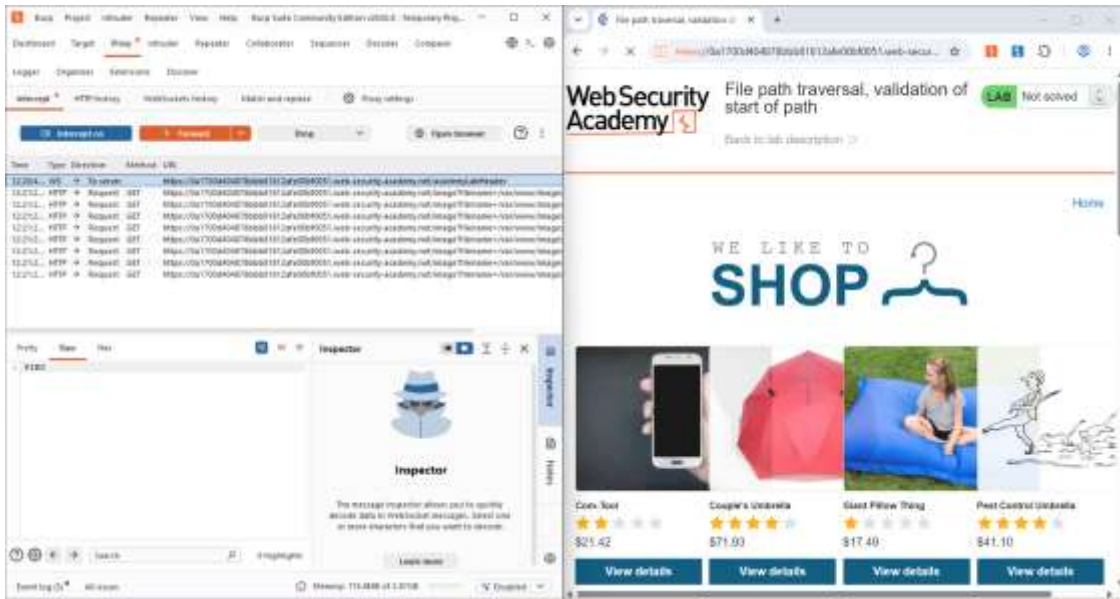


Figura 2. Historial de peticiones GET /image?filename=/var/www/images/N.jpg, mostrando la ruta completa en el parámetro.

Se seleccionó una de estas peticiones y, mediante el menú contextual, se envió a Repeater para su análisis y modificación.

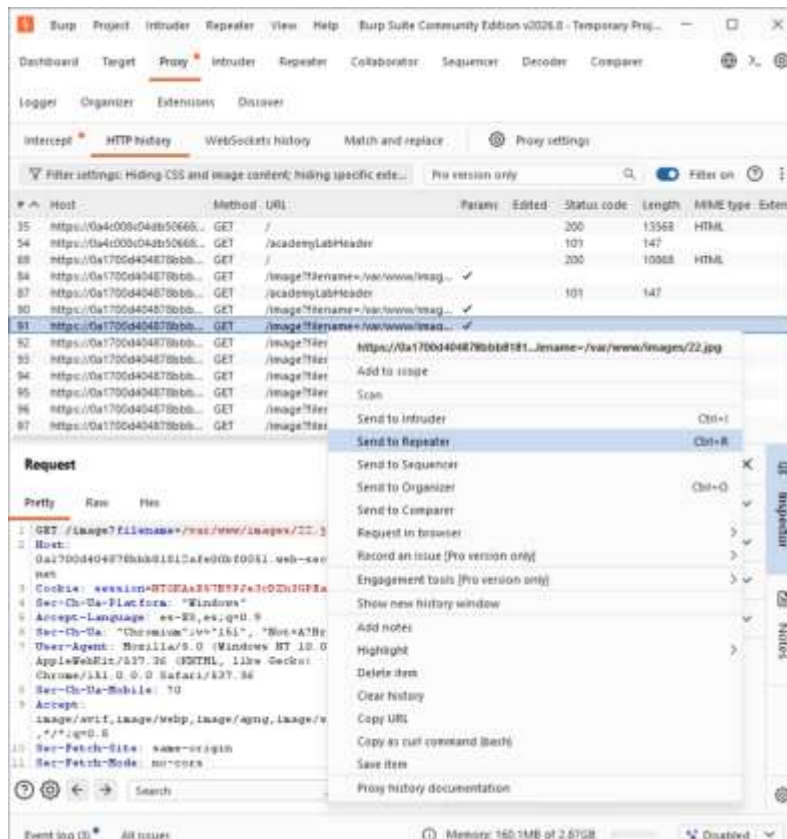


Figura 3. Envío de la petición seleccionada (filename=/var/www/images/22.jpg) a Burp Repeater mediante "Send to Repeater".

5. Fase 2: Confirmación de la validación de prefijo

Dentro de Repeater se confirmó el valor original del parámetro: la ruta absoluta completa /var/www/images/22.jpg, seleccionada en el Inspector.

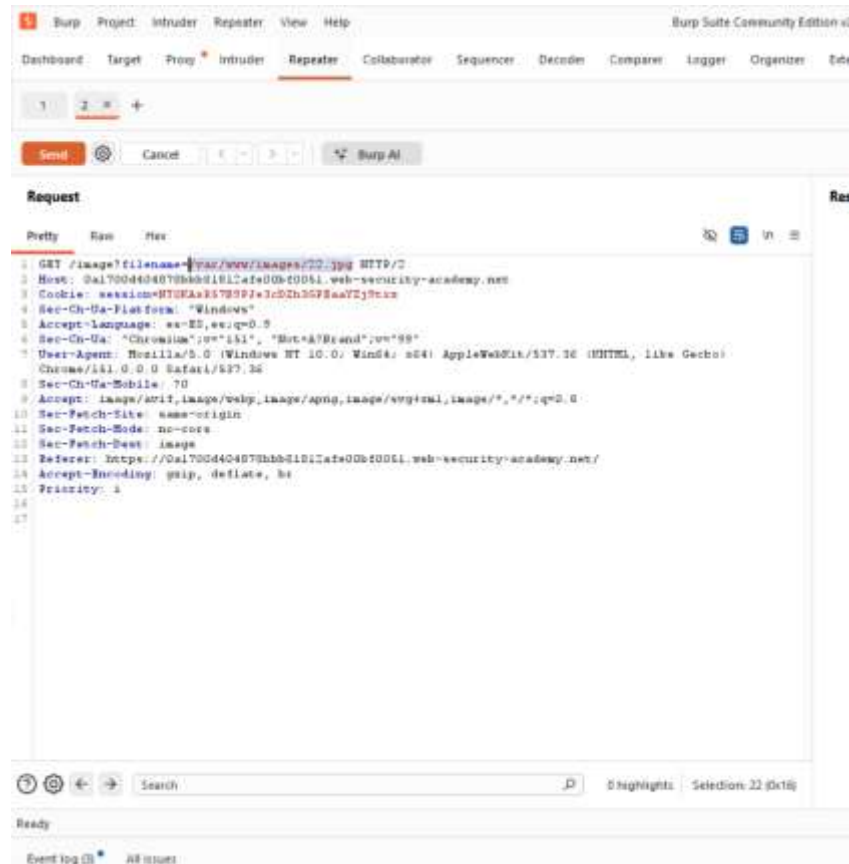


Figura 4. Petición original GET /image?filename=/var/www/images/22.jpg en Repeater, con el valor resaltado en el Inspector.

Esta observación llevó a la hipótesis de que la aplicación probablemente valida el parámetro comprobando únicamente que comience con /var/www/images/, sin examinar el resto de la cadena.

6. Fase 3: Construcción del payload y explotación

Se modificó la petición conservando el prefijo válido /var/www/images/ y añadiendo, a continuación, secuencias de retroceso de directorio seguidas de la ruta al archivo objetivo:

```
GET /image?filename=/var/www/images/../../../../etc/passwd HTTP/2
```

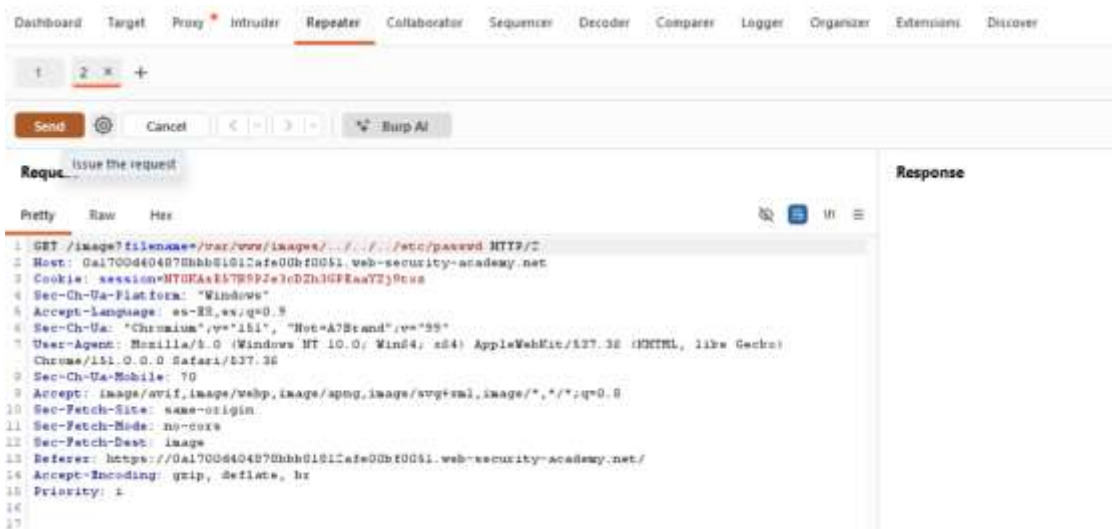


Figura 5. Petición modificada en Repeater: filename=/var/www/images/../../../../etc/passwd.

Al enviar la petición modificada, el servidor respondió con un código HTTP 200 OK y devolvió el contenido íntegro del archivo /etc/passwd.

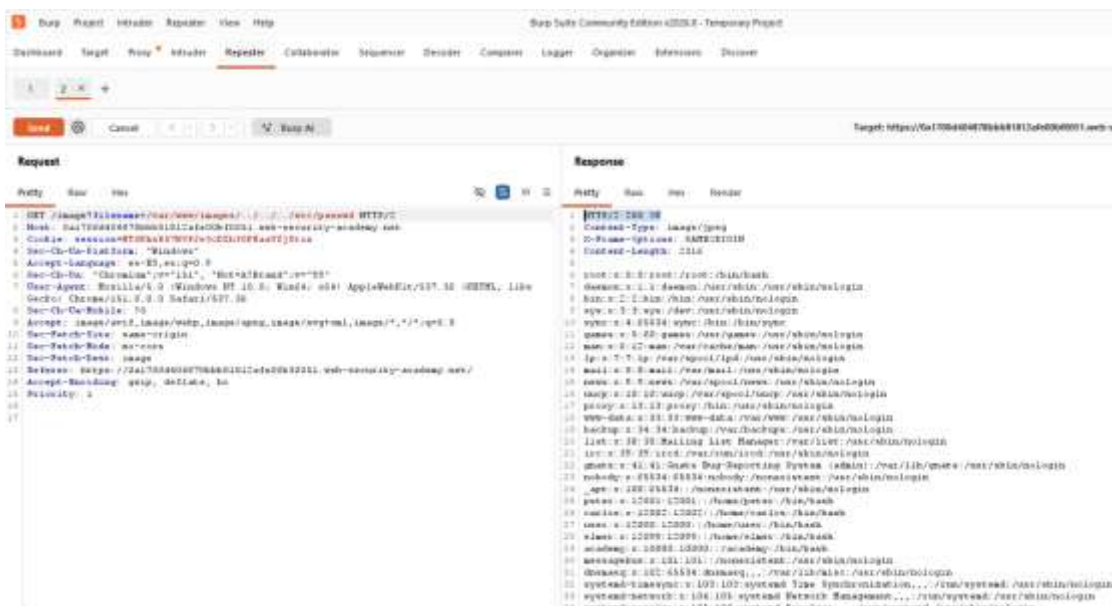


Figura 6. Respuesta HTTP 200 OK del servidor tras el envío del payload modificado.

6.1 Explicación del payload

El payload `/var/www/images/../../../../etc/passwd` puede descomponerse en dos partes con propósitos distintos:

- `/var/www/images/` : este prefijo satisface exactamente la comprobación que realiza la aplicación (`path.startsWith("/var/www/images/")`), por lo que la validación de seguridad se supera sin ningún problema.
- `../..../etc/passwd`: una vez superada la validación, estas secuencias de retroceso de directorio se procesan de forma normal por el sistema operativo al resolver la ruta completa, subiendo tres niveles desde `/var/www/images/` y descendiendo después hasta `etc/passwd`.

El resultado final, una vez que el sistema operativo normaliza la ruta completa, es simplemente `/etc/passwd` —muy distinto del directorio `/var/www/images/` que la validación pretendía garantizar—, a pesar de que la cadena original efectivamente “comenzaba” con el prefijo correcto.

Concepto teórico: validación de prefijo frente a resolución de ruta. Este laboratorio ilustra una discrepancia fundamental entre validar una cadena de texto y validar el recurso al que esa cadena termina apuntando una vez resuelta por el sistema operativo. La comprobación `startsWith` opera sobre la representación textual de la ruta antes de cualquier normalización, mientras que el sistema de archivos interpreta “../” como una instrucción de navegación real. La mitigación correcta consiste en normalizar (resolver) la ruta primero y validar el resultado canonical, nunca al revés.

6.2 Resolución del laboratorio

Al confirmar que la respuesta contenía el archivo `/etc/passwd`, PortSwigger marcó automáticamente el laboratorio como resuelto.

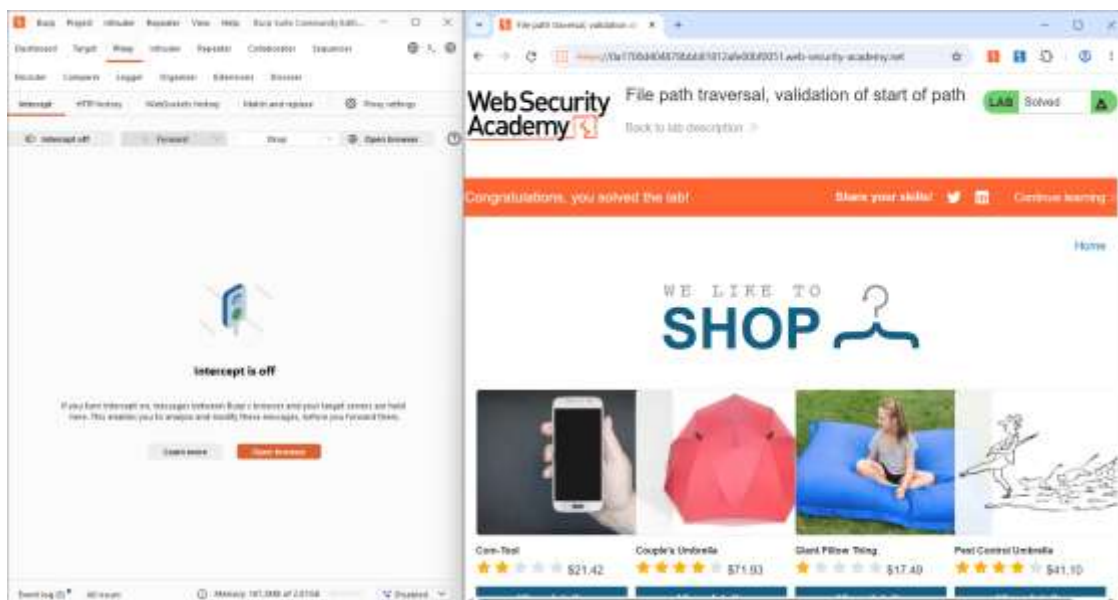


Figura 7. Confirmación de PortSwigger: “Congratulations, you solved the lab!”

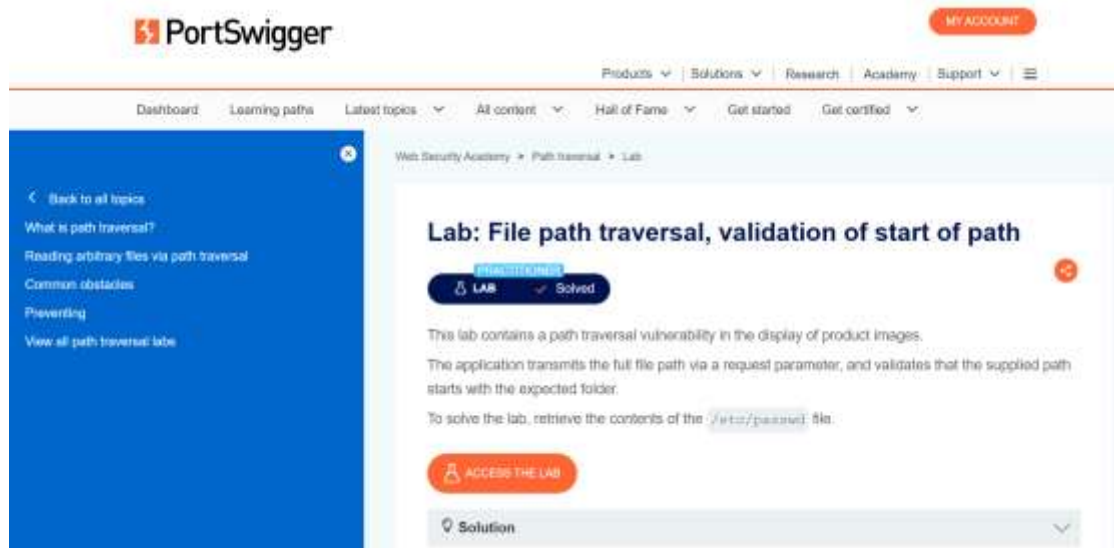


Figura 8. Estado final del laboratorio marcado como “Solved” en la página de descripción.

7. Mitigación recomendada

Para prevenir este tipo de bypass de validación de prefijo, se recomienda:

- Nunca validar únicamente el prefijo de la ruta recibida; siempre resolver (normalizar) la ruta completa a su forma canónica antes de realizar cualquier verificación de seguridad.
- Verificar que la ruta canónica resultante, después de la normalización, comience con el directorio base permitido —y no la cadena original sin procesar.
- Evitar por completo que el cliente controle rutas absolutas; preferir el envío de identificadores indirectos (por ejemplo, un ID numérico) que el servidor resuelva internamente contra una lista de archivos permitidos.
- Ejecutar el servicio con mínimo privilegio y aislar el proceso mediante chroot jail o contenedores.
- Incluir pruebas automatizadas específicas que verifiquen el comportamiento de la validación frente a rutas con secuencias de traversal incluidas después de un prefijo válido.

8. Conclusiones

Este laboratorio demostró que una validación basada únicamente en el prefijo de una cadena de texto no garantiza el control sobre la ubicación real del recurso al que finalmente se accede. La lección central es que las validaciones de seguridad relacionadas con rutas de archivos deben aplicarse siempre sobre la ruta ya normalizada (canonical), y no sobre su representación textual original, ya que el sistema operativo interpreta elementos como “../” de forma semánticamente distinta a como los interpreta una simple comparación de cadenas.